

On July 17th 2024, it was announced at the State Opening of Parliament that the Labour government will introduce the Cyber Security and Resilience Bill (CS&R). The proposed legislation is intended to update the existing Network and Information Security Regulations 2018, known as UK NIS. CS&R will strengthen the UK's cyber defences and resilience to hostile attacks thus ensuring that the infrastructure and critical services relied upon by UK companies are protected by addressing vulnerabilities, while ensuring the digital economy can deliver growth.

The legislation will expand the remit of the existing regulations and put regulators on a stronger footing, as well as increasing the reporting requirements placed on businesses to help build a better picture of cyber threats. Its aim is to strengthen UK cyber defences, ensuring that the critical infrastructure and digital services which companies rely on are secure. The Bill will extend and apply UK-wide.

The new laws are part of the Government's pledge to enhance and strengthen UK cyber security measures and protect the digital economy. CS&R will introduce a comprehensive regulatory framework designed to enforce stringent cyber security measures across various sectors. This framework will include mandatory compliance with established cyber security standards and practices to ensure essential cyber safety measures are being implemented. Ultimately, businesses will need to demonstrate their adherence to these standards through regular audits and reporting. Also included in the legislation are potential cost recovery mechanisms to provide resources to regulators and provide powers to proactively investigate potential vulnerabilities.

The 'Cyber Security and Resilience (Network and Information Systems) Bill' was given its 1st reading in the UK Parliament on 12 November 2025. A second reading in parliament was held in January 2026. The bill subsequently reached the committee stage, where the legislation is subject to further review. The Public Bill Committee asked anyone with "relevant expertise and experience or a special interest" in the bill to submit written feedback.

Key facts

The key facts from the King's Speech are:

i) The current UK NIS cyber security regulations play an essential role in safeguarding the UK's critical national infrastructure by placing security duties on industry involved in the delivery of essential services. These regulations cover the five sectors of transport, energy, drinking water, health and digital infrastructure, as well as some digital services including online marketplaces, online search engines, and cloud computing services. 12 regulators are responsible for implementing the present regulations.

ii) Hostile cyber actors are increasingly targeting UK critical sectors and supply chains. Recent serious high-profile attacks impacting London hospitals and the Ministry of Defence, as well as ransomware attacks on the British Library and Royal Mail, have highlighted that UK services and institutions are vulnerable to attack.

iii) The impacts of a cyber attack on these sectors pose severe risks to UK citizens, core services and the economy at large. For example, as a result of the ransomware attack affecting the NHS in England in June [2024], 3,396 outpatient appointments and 1,255 elective procedures were postponed across King's College Hospital, Guy's Hospital and St Thomas' Hospital, all in South London. It has been estimated that the cost of cybercrime in the UK in 2023 was \$320 billion, near £225 billion.

iv) The National Cyber Security Centre (NCSC) assess that the increased threat from hostile states and state-sponsored actors continues to escalate. At a recent speech at CyberUK, NCSC CEO Felicity Oswald warned that providers of essential services in the UK cannot afford to ignore these threats.

v) 2 UK NIS Post-Implementation Reviews found that the original regulations are having a

positive impact, but that progress has not been fast enough. In 2022 the review found that they "are a vital framework in raising wider UK resilience against network and information systems security threats", but updates are required to keep pace with growing threats. Just over half of the operators of essential services have updated or strengthened existing policies and processes since the inception of the UK NIS Regulations in 2018, which were introduced after EU NIS Directive 2016/1148.

Consequences

It will introduce compulsory ransomware reporting so that the authorities can better understand the threat and "alert us to potential attacks by expanding the type and nature of incidents that regulated entities must report." While this information collection is likely to increase resilience to attacks, the administrative burden for businesses from this reporting might well bring with it additional costs as well as the original cyber incident's expense.

As modern business practices are interconnected, organisations must ensure that their partners and suppliers also adhere to the standards set by the CS&R.

In the EU, the original Network and Information Security Directive (NIS Directive 2016/1148) is being updated to Directive 2022/2555, known as EU NIS 2. EU NIS 2 introduces wide-reaching changes to the existing EU cyber security laws for network and information systems. The CS&R should bring the existing UK NIS regulations 2018 to a framework similar to that of the EU.

The Bill as yet has no information on any punishments for non-compliance or what the data regulators' demands from an organisation that has experienced a cyber security incident will be. It was announced in April 2025 by Peter Kyle, UK Secretary of State for Department for Science, Innovation and Technology, that there would be £100,000 a day fines for failing to act against relevant threats.

Reaction

Jon Ellison, NCSC Director of National Resilience, said that the proposed bill was "a landmark moment tackling the growing threat to the UK's critical systems". He continued that it will be "a crucial step towards a more comprehensive regulatory regime, fit for our volatile world".

Former head of the NCSC Ciaran Martin along with other experts welcomed the legislative proposal. On social media, he wrote that the proposed legislation seemed sensible, with mandatory reporting requirements being significant and positive steps.

A representative of the CyberUp Campaign Matt Hull said that the organisation is looking forward to the Government updating UK cyber resilience and in particular the Computer Misuse Act 1990. Any updates to this Act would help cyber professionals protect the U.K., safeguard the digital economy and unlock the potential growth within the cybersecurity industry.

Cyber security and resilience policy statement

In April 2025, the CS&R Policy Statement was published, which outlines the confirmed and proposed measures to be included in the bill. Quoting: "The digital revolution is transforming our Critical National Infrastructure (CNI) and our essential public services. It offers an extraordinary opportunity – to make our people and our country better off. However, it may also bring new and dangerous vulnerabilities... In this Policy Statement, I set out legislative proposals for this Bill. I also acknowledge that the cyber landscape moves exponentially – a lot can happen in a short space of time. This statement proposes several additional measures to tackle the threats that we are facing now."

The legislation aims to strengthen the UK's cyber defenses and secure critical infrastructure and essential digital services, thereby enhancing CNI protection. The statement details plans to expand the regulatory framework to cover more entities, empower regulators and improve oversight. This includes enhancing incident reporting, augmenting the ICO's

information-gathering capabilities and improving regulators' cost recovery mechanisms. The bill also addresses the need for an adaptable regulatory framework to keep pace with the ever-evolving cyber landscape.

CS&R seeks to broaden the scope of organizations required to improve their risk assessments, strengthening cybersecurity measures for approximately 1000 organizations. These measures will increase data protection and network security and are likely to include data center operators and managed service providers. The proposals also include giving regulators more tools to enhance security standards, mandating detailed incident reporting and granting the government powers to update regulatory frameworks as threats and technology evolve.

The statement provides a detailed overview of the changes to the Cyber Essentials program, including updates to the software definition, vulnerability fixes and terminology related to remote working. The Cyber Essentials Plus test specification will be updated with new verification pointers, verification of segregation by sub-set and verification of sampling. The statement also outlines the steps organizations will need to take to achieve Cyber Essentials certification in 2025 and onwards. These include changes to IT infrastructure requirements, such as the introduction of passwordless authentication.

Schedule

17 July 2024 - Bill announced.

1 April 2025 - Cyber security and resilience policy statement.

12 November 2025 - First reading: The Bill was introduced to Parliament.

6 January 2026 - Second reading.

22 January 2026 - NISR Keeling Schedule showing changes proposed by the CS&R bill.

24 February 2026 - Compilation of the 7 committee stages up until 24 February 2026 published (current).

16 June 2026 - The Bill has now been given its third reading and has moved to the House of Lords for the Committee stage.

See also

Cyber Resilience Act - EU regulation to improve cybersecurity and cyber resilience.

Deepfake - Realistic artificially generated media.

GDPR - The General Data Protection Regulation.

Malware - Examples include Computer viruses, spyware and adware.

References

External links

Cyber security and resilience policy statement April 2025

Cyber security in the UK Research Briefing - House of Commons Library